

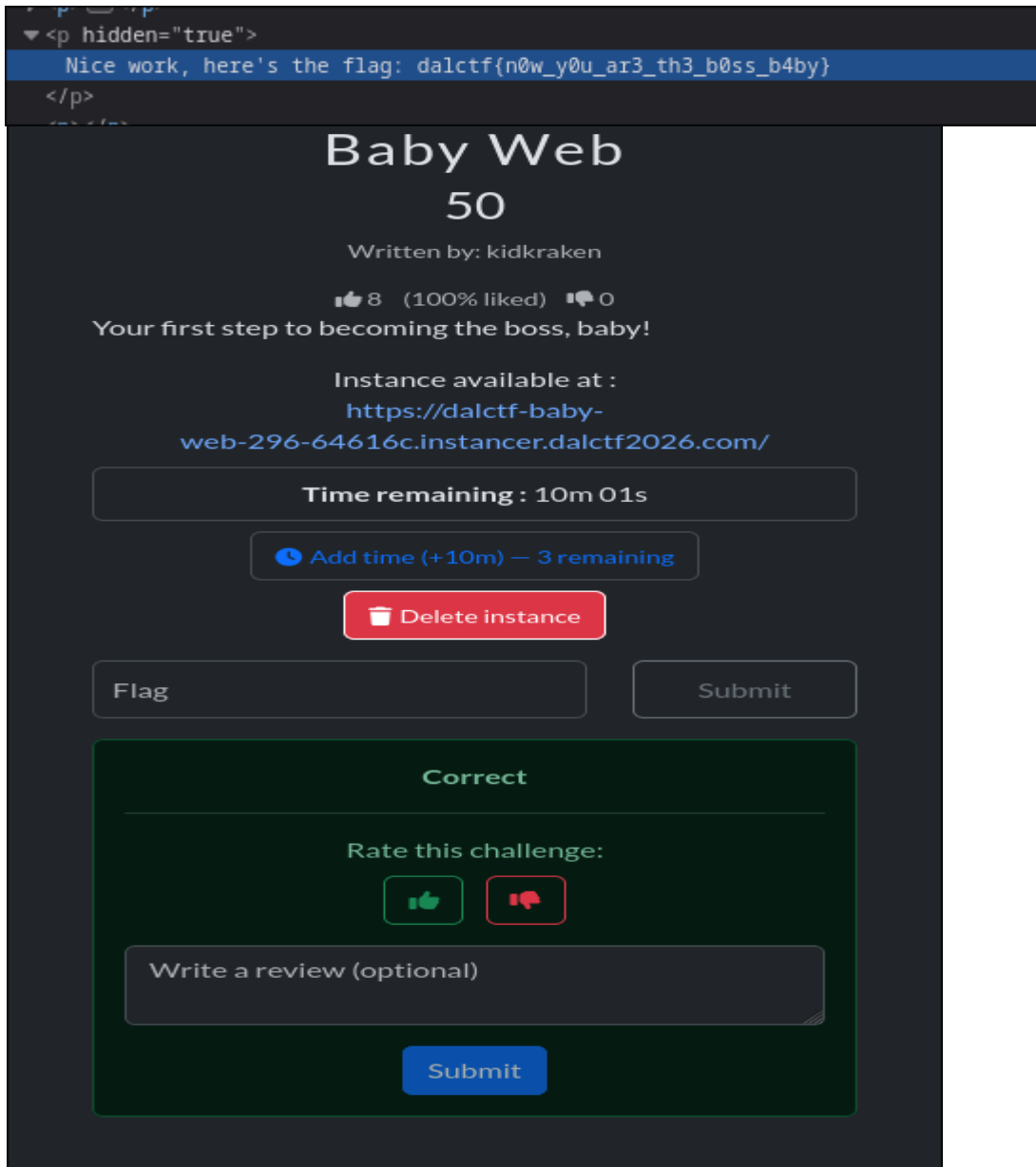
## Exercise sheet 02

### 1.1: DalCTF 2026

#### 1.1.2.web.

#### 1.1.2.web.1: Challenge “Baby Web”

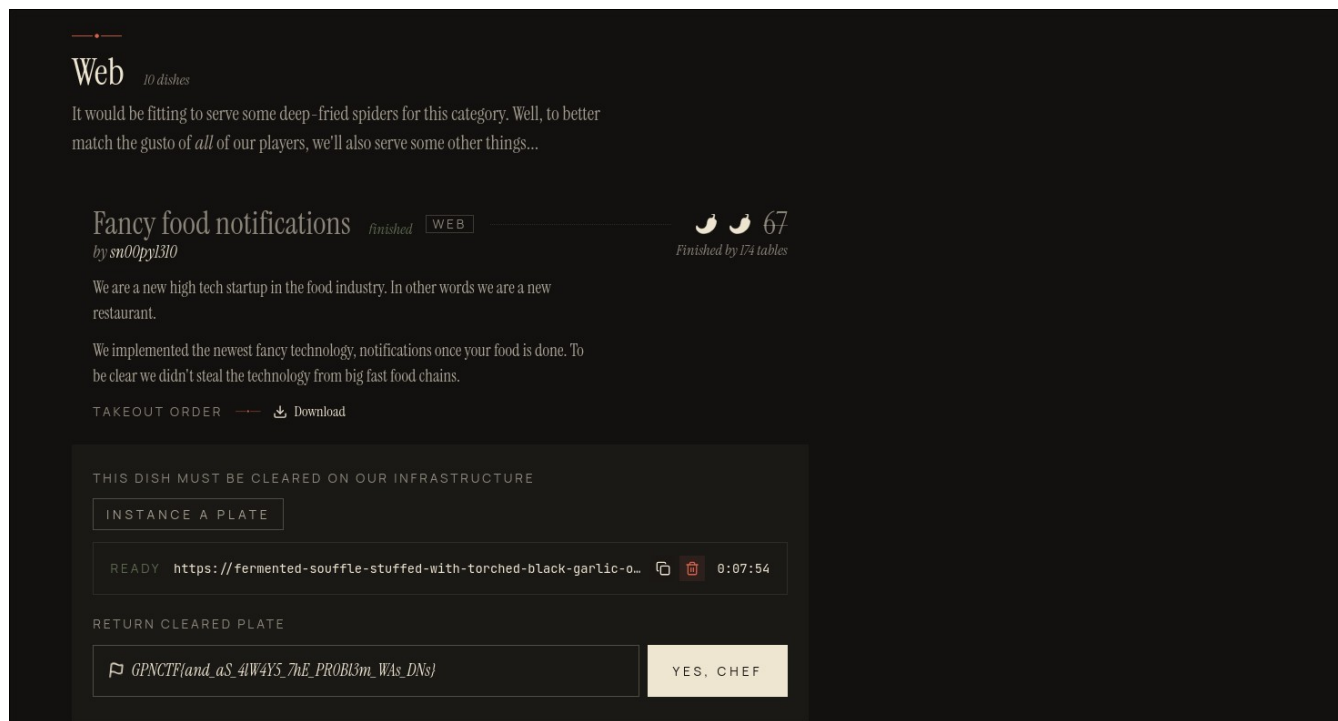
I generated the site, got to it, saw a large text, pressed CTRL + SHIFT + C to open Dev tools, save a paragraph with hidden=”true”, which I then opened, and it had the flag in it.



## 1.2: GPN CTF 2026

### 1.2.2.web.2: Challenge “Fancy food notifications”

I entered a webhook as URL, which then got me the Authorization Bearer Token, which I then decode with the HS256 algorithm, so that I can encode a payload with “vip”: true, “id”: <its id> and can create a second order with the newly encoded payload and key @127.0.0.1\@<some website>/../vip-meal to get to the vip meal flag.



### 1.2.2.misc.pwning: Challenge “Recipe for Disaster”

I inspected the C code, saw that the note has a max size of 32 characters, I repeated the procedure until it got to an overflow and resulted in a negative price so that I could get a coupon with the flag in it.

Added: Overwritten Return Pointer (\$1801546934)

| TODAY'S MENU |                            |      |
|--------------|----------------------------|------|
| #            | Item                       | \$   |
| 1            | Overwritten Return Pointer | 1337 |
| 2            | Gulasch                    | 23   |
| 3            | Deep Fried XSS             | 13   |
| 4            | Pizza Crypto               | 11   |
| 5            | Scrambled VM Instruction   | 18   |
| 6            | Grilled Bits               | 6    |

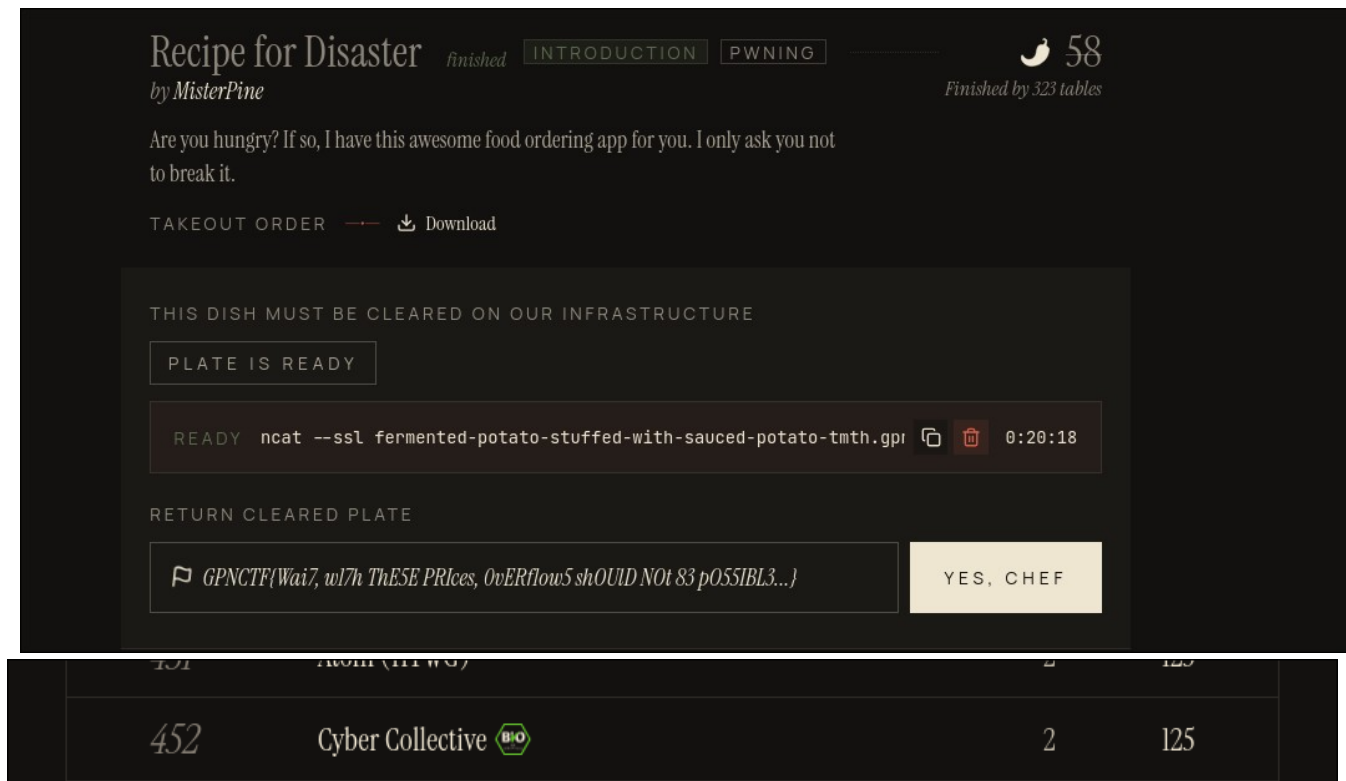
```
Added: Overwritten Return Pointer ($-1228709525)
```

| TODAY'S MENU |                            |      |
|--------------|----------------------------|------|
| #            | Item                       | \$   |
| 1            | Overwritten Return Pointer | 1337 |
| 2            | Gulasch                    | 23   |
| 3            | Deep Fried XSS             | 13   |
| 4            | Pizza Crypto               | 11   |
| 5            | Scrambled VM Instruction   | 18   |
| 6            | Grilled Bits               | 6    |

```
===== YOUR RECEIPT =====
Overwritten Return Pointer $1718774372
(note: rtsaetaemn,fedafkjask,fdsjlk)
Overwritten Return Pointer $1634364262
(note: jfaljfkdlajlajfldkjakljfjdkalfja)
Overwritten Return Pointer $1684433372
(note: jfkldadjflkajdfklajfjölkaödfkæ)
Overwritten Return Pointer $1823916900
(note: fkaöflkdöflkälöfkdlöfkalöf)
Overwritten Return Pointer $1801546934
(note: kfljakjdfklaföäakföälkdföäkf)
Overwritten Return Pointer $-1228709525
(note: fkalökdöfakfaköfkaöflkaldö)
```

[SYSTEM] Pricing error detected! We sincerely apologise for  
[SYSTEM] the inconvenience. Please accept this coupon:

```
GPNECTF{Wai7, w17h ThE5E PRICES, 0vERf1ow5 shOUlD NOt 83 p055IBL3...}
```



2.

2.1. Format: CVE ID (EUVD ID): CVSS Score v3.1

- I. CVE-2025-9230 (EUVD-2025-31729): 7.5
- II. CVE-2025-9231 (EUVD-2025-31728): 6.5
- III. CVE-2025-9232 (EUVD-2025-31727): 5.9
- IV. CVE-2025-4575 (EUVD-2025-16128): 6.5
- V. CVE-2024-12797 (EUVD-2024-51115): 6.3
- VI. CVE-2024-13176 (EUVD-2024-51400): 4.1

Vulnerability chosen for further tasks: CVE-2025-9230

## 2.2.

Vulnerability: check of the inlen inside the key\_unwrap\_key() function is off by 8 bytes which enables to possibility to overread up to 8 bytes and thus overwrite up to 4 bytes.

```
kek_unwrap_key(): Fix incorrect check of unwrapped key size
Fixes CVE-2025-9230

The check is off by 8 bytes so it is possible to overread by
up to 8 bytes and overwrite up to 4 bytes.

Reviewed-by: Neil Horman <nhorman@openssl.org>
Reviewed-by: Matt Caswell <matt@openssl.org>
Reviewed-by: Tomas Mraz <tomas@openssl.org>
(cherry picked from commit 9c462be)

openssl-3.5 · openssl-3.5.6 ... 3.5-POST-CLANG-FORMAT-WEBKIT 1 parent 033a348 commit bae259a

1 file changed
```

```
Filter files... Search within code

crypto/cms
  cms_pwri.c

crypto/cms/cms_pwri.c
242 242      /* Check byte failure */
243 243      goto err;
244 244  }
245 245  - if (inlen < (size_t){tmp[0] - 4}) {
```

## 2.3

```
245 + if (inlen < 4 + (size_t)tmp[0]) {
246 246      /* Invalid length value */
247 247      goto err;
248 248  }
```

Fix: Instead of subtracting 4, 4 is added. Enough buffer so that no data is overwritten.

## 2.4.

CWE-125 Out-of-bounds Read, CWE-787 Out-of-bounds Write.

2.5. This vulnerability most definitely could have been found earlier and reminds me of some kind of off-by-one error, where they subtract instead of adding 4. But it also

could have been avoided by using typesafe and memory safe languages like Rust where such bugs become compile-time errors (so they can be found easily) or become straight-up impossible to be caused, and avoid unsafe languages like C.

Developers also can learn from this to always test their code to avoid such grave memory safety bugs.